INFORME CONSOLIDADO DE RETEST QA

Escenarios G2-21, G2-31, G2-32 y G2-33

Proyecto: UDV — Proyecto G6 QA | Fecha de ejecución: 05 de noviembre de 2026

Ambiente principal: API desplegada en Railway | Herramientas: Swagger UI, PowerShell y curl.exe

1. Objetivo y alcance

Documentar los resultados y hallazgos de los cuatro retests solicitados por el Project Manager: control de acceso y descarga de archivos (G2-21), paginación (G2-31), fechas ISO 8601 en UTC con Z (G2-32) y concordancia de OpenAPI con la API real (G2-33).

2. Resumen ejecutivo

Escenario	Pruebas realizadas	Resultado	Hallazgo principal
G2-21 — Acceso a archivos	4/4 PASS	PASS	Propietario/admin descargan (200); otro usuario recibe 403
G2-31 — Paginación	satisfactorias	PASS funcional	Validaciones, límites, valores por defecto y páginas correctas.
G2-32 — Fechas	8 / 8 satisfactorias	PASS funcional	32 campos de fecha válidos con ISO 8601 y sufijo UTC Z.
G2-33 — OpenAPI	Comparaciones documentales y respuestas reales	FAIL documental	Códigos HTTP omitidos y esquemas que no representan la API.

Balance: tres escenarios presentan resultados PASS dentro de las pruebas realizadas (G2-21, G2-31 y G2-32); G2-33 permanece en FAIL documental. La validación de seguridad de G2-21 confirmó el bloqueo de descarga por un usuario distinto del propietario. Las observaciones se limitan a los casos y datos examinados.

3. G2-21 — Control de acceso y descarga de archivos

Se repitieron cuatro pruebas de acceso a archivos. Se utilizó el archivo “Prueba QA 05_11_26.pdf” (ID 3) y el endpoint GET /api/v1/files/3. El objetivo fue comprobar que la descarga esté permitida únicamente al propietario o a un administrador, y prohibida a otro usuario autenticado sin autorización.

Prueba	Respuesta observada	Resultado
G2-21_01 — Subida del archivo por su propietario	HTTP 200 OK	PASS
G2-21_02 — Descarga por propietario (docente1)	HTTP 200 OK; contenido application/pdf	PASS
G2-21_03 — Descarga por otro usuario (docente2)	HTTP 403 Forbidden; código FORBIDDEN	PASS
G2-21_04 — Descarga por administrador	HTTP 200 OK; contenido application/pdf	PASS

Hallazgo: el control de autorización impide la descarga por un usuario distinto del propietario, mientras que permite la descarga al titular y al administrador. En la prueba denegada, la API devolvió el mensaje “No tienes permiso para acceder a este archivo”. Se corroboró la entrega del PDF en las descargas autorizadas.

Resultado G2-21: PASS (4/4). El problema previo de acceso indebido no se reprodujo en las pruebas actuales. Este resultado acredita los casos observados, sin sustituir una auditoría exhaustiva de seguridad.

4. G2-31 — Validación de paginación

Endpoint: GET /api/v1/users. Se ejecutaron 22 pruebas de parámetros de paginación. Todas produjeron el comportamiento esperado en las respuestas observadas.

Grupo de pruebas	Hallazgo comprobado
Valores inválidos	page y per_page rechazan 0, negativos, texto no numérico, decimales y valores vacíos mediante HTTP 422.
Límites	per_page=1 y per_page=100 son aceptados; 101 y 1000 se rechazan con HTTP 422. Rango observable: 1–100.
Navegación	Segunda página con 5 usuarios; última página con 1; página fuera de rango con HTTP 200 y data vacío.
Valores predeterminados	Omitir ambos parámetros aplica page=1, per_page=20; omitir uno mantiene su respectivo valor por defecto.
Errores simultáneos	page=0 y per_page=101 producen dos errores de validación; ambos parámetros vacíos también se reportan.

Resultado G2-31: PASS (22/22). Durante estas consultas la API reportó total=16 usuarios; dicho total corresponde a la respuesta del endpoint en ese momento y no prueba la inexistencia de registros ocultos, históricos o de otros ambientes.

5. G2-32 — Formato y zona horaria de fechas

Endpoint: GET /api/v1/users. Se repitieron ocho comprobaciones, incluyendo muestras de usuarios en distintas páginas y verificaciones automáticas de los 16 usuarios accesibles por la consulta paginada.

Validación	Resultado observado
Presencia de campos	creado_en y actualizado_en presentes en los usuarios examinados.
Formato	32 de 32 campos cumplen el patrón ISO 8601 comprobado.
Validez	32 de 32 fechas se interpretaron correctamente como fechas reales mediante PowerShell.
Cronología	En 16 de 16 usuarios, actualizado_en es igual o posterior a creado_en.
Zona horaria	32 de 32 campos terminan en Z (representación UTC).

La nota del PM especifica explícitamente “creado_en y actualizado_en en UTC con Z”; por ello la zona horaria observada coincide con lo solicitado para este retest. Las pruebas confirmaron la reaparición de los campos de fecha, que habían estado ausentes en una revisión anterior.

6. G2-33 — Coincidencia entre OpenAPI y la API

Se compararon las secciones Responses y ejemplos de Swagger con respuestas reales en Railway para POST /api/v1/users, GET /api/v1/me y GET /api/v1/users. Persisten las siguientes discrepancias:

ID	Hallazgo documental	Comprobación y alcance
H-01	POST /users omite HTTP 409	Swagger muestra 201 y 422; HTTP 409 se había reproducido en una evidencia histórica del ambiente local, no nuevamente en Railway.
H-02	POST /users muestra “string” como respuesta HTTP 201	El ejemplo es genérico; la estructura real exacta de una nueva creación HTTP 201 no se reprodujo en el retest actual.

H-03	POST /users documenta HTTP 422 con esquema genérico	Railway devuelve error.code, error.message y error.details como objeto por campo; Swagger muestra el esquema de FastAPI basado en detail.
H-04	GET /me muestra “string” para HTTP 200	Railway devuelve objeto JSON con datos de usuario, roles y permisos. HTTP 401 sí está documentado.
H-05	GET /users muestra “string” para HTTP 200 y omite HTTP 403	Railway devuelve objeto con page, per_page, total, data; con cuenta docente devuelve 403 FORBIDDEN que Swagger marca Undocumented.

Resultado funcional complementario: la API devolvió correctamente HTTP 422 para una creación inválida, con details como objeto cuyas llaves fueron nombres, apellidos, correo, password y rol. También aplicó HTTP 403 a un docente que intentó consultar usuarios. Estos comportamientos correctos no subsanan las diferencias de documentación.

Resultado G2-33: FAIL documental.. La revisión del caso 409 cuenta con respaldo de una prueba local previa; corresponde distinguirla de las comprobaciones actuales en Railway.

7. Acciones recomendadas y cierre

1. Conservar las cuatro evidencias de G2-21 como comprobación de control de acceso por propietario y administrador; repetir la autorización si cambian reglas de roles o permisos.
2. Actualizar OpenAPI para incluir HTTP 409 en POST /api/v1/users y HTTP 403 en GET /api/v1/users, con ejemplos y modelos de error reales.
3. Reemplazar los ejemplos genéricos “string” de HTTP 200/201 por los esquemas JSON correctos; reconfirmar específicamente la respuesta HTTP 201 de creación antes de cerrar ese punto.
4. Alinear el modelo HTTP 422 de Swagger con la respuesta efectiva error.code, error.message y error.details como objeto por campo.
5. Desplegar la actualización documental y repetir G2-33 en Railway conservando capturas de las secciones Responses y de las respuestas observadas.

Conclusión general: G2-21, G2-31 y G2-32 cumplen las pruebas funcionales efectuadas y se registran como PASS. G2-33 permanece en FAIL documental por códigos HTTP y esquemas de respuesta que todavía no reflejan el comportamiento observado. El cierre de G2-33 requiere actualización de OpenAPI y nuevo retest.